

BÁO CÁO DỰ ÁN

Hệ thống SecureChat

NGUYỄN VŨ THÀNH

Thanh14704@gmail.com

Lĩnh Vực: Kỹ Sư Phần Mềm: Lập Trình Hệ Thống

Mentor hướng dẫn: Lê Thành Thân

Đơn vị: Viettel Cypher Security

Chương trình: Viettel Digital Talent

HÀ NỘI, 6/2026

TÓM TẮT NỘI DUNG DỰ ÁN

Dự án trình bày việc thiết kế và phát triển hệ thống SecureChat - một giải pháp truyền thông thời gian thực (Real-time Communication) theo mô hình Client-Server. Hệ thống được xây dựng hoàn toàn bằng ngôn ngữ C++ với mục tiêu đáp ứng đồng thời hai yêu cầu : Hiệu năng xử lý đồng thời cao ở mức cao (High Concurrency) và Bảo Mật thông tin đa lớp.

Ở phía Máy chủ (Server), kiến trúc hệ thống được thiết kế dựa trên mô hình điều khiển sự kiện bất đồng bộ (Event-Driven) sử dụng *epoll*, kết hợp cùng mô hình Thread Pool. Điều này cho phép Server xử lý bài toán C10K một cách tối ưu, không bị thất nút cổ chai tại các luồng I/O mạng. Cơ sở dữ liệu SQLite được tích hợp cùng cơ chế Write-Ahead Logging (WAL) giúp đảm bảo tốc độ truy vấn thông tin người dùng và lịch sử hệ thống trong môi trường đa luồng.

Về mặt Giao thức và Bảo mật, hệ thống không sử dụng các giao thức văn bản truyền thống mà lựa chọn sử dụng giao thức truyền tải nhị phân tùy chỉnh (Custom Binary Protocol) với Header chứa mã kiểm lỗi CRC32. Quá trình bảo mật áp dụng mô hình mã hóa lai (Hybrid Crypto): sử dụng RSA-2048 để trao đổi khóa phiên một cách an toàn ở bước bắt tay (Handshake), sau đó toàn bộ payload giao tiếp được mã hóa và xác thực tính nguyên vẹn bằng chuẩn AES-256-GCM.

Ngoài ra, dự án tập trung nghiên cứu và cài đặt một dịch vụ an ninh mạng chủ động ngay trong nhân máy chủ, bao gồm: module Hệ thống phát hiện xâm nhập (Intrusion Detector - IDS) để phân tích hành vi độc hại, bộ định tuyến giới hạn tốc độ (Rate Limiter) chống lại các cuộc tấn công DoS/Spam dựa trên thuật toán Token-Bucket, và Nhật ký kiểm tra (Audit Logger) lưu vết các thao tác nhạy cảm. Phía Client cài đặt giao diện dòng lệnh (CLI) nhẹ, hỗ trợ đa dạng tính năng nghiệp vụ từ nhắn tin cá nhân, phòng chat nhóm, truyền tải tập tin, đến các tập lệnh của quản trị viên (Admin Commands).

Kết quả đạt được là một nền tảng giao tiếp tin cậy, hoạt động ổn định và đáp ứng các tiêu chuẩn bảo mật thực tế, có khả năng mở rộng và tích hợp thêm các dịch vụ khác trong tương lai.

MỤC LỤC

Danh sách hình vẽ	iii
Danh sách bảng	iv
CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI	1
1.1 Khảo sát hiện trạng	1
1.1.1 Đặt vấn đề	1
1.1.2 Mục tiêu và phạm vi của đề tài	2
1.2 Phân tích yêu cầu hệ thống	3
1.2.1 Yêu cầu chức năng	3
1.2.2 Yêu cầu phi chức năng	4
CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	6
2.1 Kiến trúc mạng và giao thức	6
2.1.1 Mô hình Client-Server	6
2.1.2 Giao thức TCP/IP	7
2.2 Công nghệ mã hóa và bảo mật	8
2.2.1 Mã hóa đối xứng AES	8
2.2.2 Mã hóa bất đối xứng RSA	9
2.2.3 Hàm băm SHA-256 và xác thực HMAC	10
2.3 Công nghệ xử lý đồng thời và hiệu năng cao	11
2.3.1 I/O Multiplexing và mô hình epoll	11
2.3.2 Mô hình Thread Pool	13
2.4 Lý thuyết an ninh mạng	14
2.4.1 Hệ thống phát hiện xâm nhập (IDS)	14
2.4.2 Thuật toán Rate Limiting (Token-Bucket)	15
2.5 Hệ thống lưu trữ và cơ sở dữ liệu	16
2.5.1 Cơ sở dữ liệu SQLite	16
2.5.2 Cơ chế Write-Ahead Logging (WAL)	17
2.6 Công cụ và Thư viện phát triển	18

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG	20
3.1 Kiến trúc tổng thể hệ thống	21
3.1.1 Kiến trúc Server	21
3.1.2 Kiến trúc Client	21
3.2 Thiết kế giao thức giao tiếp	21
3.2.1 Cấu trúc gói tin	21
3.2.2 Luồng xử lý thông điệp	21
3.3 Thiết kế cơ chế bảo mật	21
3.3.1 Cơ chế trao đổi khóa (Key Exchange)	21
3.3.2 Xác thực người dùng và Phục hồi phiên (Auth & Session Resumption)	21
3.4 Thiết kế hệ sinh thái an ninh mạng chủ động	21
3.4.1 Hệ thống phát hiện xâm nhập (IDS)	21
3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)	21
3.4.3 Nhật ký kiểm toán (Audit Logger)	21
3.5 Thiết kế cơ sở dữ liệu	21
3.5.1 Sơ đồ thực thể liên kết (ERD)	21
3.5.2 Quản lý người dùng và trạng thái	21
3.6 Thiết kế logic tính năng nghiệp vụ	21
3.6.1 Nhắn tin cá nhân và Bộ lọc nội dung (Direct Message & Message Filter)	21
3.6.2 Quản lý phòng Chat nhóm (Rooms)	21
3.6.3 Cơ chế truyền tải tập tin (File Transfer)	21
3.6.4 Các tập lệnh quản trị hệ thống (Admin Commands)	21
3.7 Triển khai và Đánh giá	21
3.7.1 Môi trường triển khai	21
3.7.2 Kịch bản kiểm thử chức năng (Functional Testing)	21
3.7.3 Đánh giá hiệu suất và Khả năng phòng thủ (Performance & Security Evaluation)	21
CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	22
4.1 Kết luận	22
4.2 Hướng phát triển	22

Danh sách hình vẽ

Danh sách bảng

DANH MỤC THUẬT NGỮ VÀ TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
ACK	Acknowledgment
AD	Authenticated Data
AES	Advanced Encryption Standard
CBC	Cipher Block Chaining
CLI	Command-Line Interface
CPU	Central Processing Unit
CRC	Cyclic Redundancy Check
DoS	Denial-of-Service
DDoS	Distributed Denial-of-Service
ERD	Entity-Relationship Diagram
ET	Edge-Triggered
FD	File Descriptor
GCM	Galois/Counter Mode
GUI	Graphical User Interface
HIDS	Host-based Intrusion Detection System
HMAC	Hash-based Message Authentication Code
I/O	Input/Output
IDS	Intrusion Detection System
IP	Internet Protocol
LT	Level-Triggered
MTU	Maximum Transmission Unit
OOM	Out of Memory
RSA	Rivest-Shamir-Adleman
SHA	Secure Hash Algorithm
TCP	Transmission Control Protocol
TLS	Transport Layer Security
UDP	User Datagram Protocol
WAL	Write-Ahead Logging

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

1.1 Khảo sát hiện trạng

1.1.1 Đặt vấn đề

Sự mở rộng quy mô của hạ tầng mạng Internet và thiết bị di động đã gia tăng đáng kể nhu cầu giao tiếp trực tuyến. Trong bối cảnh đó, các ứng dụng truyền thông thời gian thực (Real-time Communication) đóng vai trò nền tảng trong việc duy trì luồng trao đổi thông tin liên tục và đa chiều. Thành phần cốt lõi của các hệ thống này là kiến trúc máy chủ (Chat Server) với năng lực xử lý cao, đảm nhiệm vai trò tiếp nhận, điều phối và định tuyến thông điệp song công (full-duplex) với độ trễ thấp giữa một số lượng lớn thiết bị máy khách (Client) phân tán.

Tuy nhiên, việc thiết kế và triển khai một kiến trúc mạng đáp ứng yêu cầu trên đối mặt với nhiều thách thức kỹ thuật phức tạp, trong đó trọng tâm là bài toán tối ưu hiệu năng. Khi hệ thống phải duy trì hàng chục nghìn kết nối đồng thời (bài toán C10K), mô hình cấp phát luồng theo kết nối (thread-per-client) truyền thống thường bộc lộ những hạn chế cố hữu, gây ra hiện tượng thắt cổ chai I/O mạng (Network I/O Bottleneck) và suy kiệt tài nguyên phần cứng. Thêm vào đó, việc sử dụng các giao thức dựa trên văn bản (Text-based Protocol) làm gia tăng chi phí phân tích cú pháp (parsing overhead) và hao phí băng thông. Những vấn đề này đặt ra yêu cầu cấp thiết trong việc xây dựng hệ thống dựa trên các mô hình I/O đa kênh tiên tiến (I/O Multiplexing), kết hợp cùng thiết kế cấu trúc gói tin nhị phân (Binary Protocol) nhằm giảm thiểu kích thước dữ liệu và tối ưu hóa triệt để độ trễ truyền tải.

Bên cạnh năng lực xử lý đồng thời, việc bảo mật luồng dữ liệu truyền tải là một yêu cầu kỹ thuật mang tính tiên quyết. Nhiều kiến trúc hệ thống hiện hành vẫn bộc lộ lỗ hổng trong cơ chế kiểm soát truy cập và bảo vệ kênh truyền, làm gia tăng nguy cơ đối mặt với các hình thức tấn công mạng như nghe lén (Eavesdropping), tấn công xen giữa (Man-in-the-Middle) hay cạn kiệt tài nguyên (DoS/Spam). Việc nghiên cứu và tích hợp các module phòng thủ chủ động - bao gồm mã hóa dữ liệu, hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) và cơ chế giới hạn lưu lượng (Rate Limiter) - là giải pháp thiết yếu để chuyển đổi một máy chủ truyền thông tiêu chuẩn thành một kiến trúc giao tiếp an toàn, khép kín và có độ tin cậy cao.

Xuất phát từ những thách thức kỹ thuật và nhu cầu thực tiễn nêu trên, việc nghiên cứu, thiết kế và phát triển một hệ thống “Secure Chat Server” hiệu năng cao là một định hướng cấp thiết. Đề tài đòi hỏi việc kiểm soát toàn diện kiến trúc hệ thống, từ phần tối

ưu hóa I/O mạng, định tuyến thông điệp Client-Server tốc độ cao, cho đến việc triển khai các cơ chế bảo mật chuyên sâu đa lớp. Hướng tiếp cận này không chỉ giải quyết trọn vẹn bài toán vận hành thực tế mà còn đóng góp giá trị học thuật cao trong lĩnh vực lập trình hệ thống và an toàn thông tin.

1.1.2 Mục tiêu và phạm vi của đề tài

1. Mục tiêu của đề tài

Đề tài hướng tới việc nghiên cứu, thiết kế và phát triển hoàn chỉnh một hệ thống máy chủ truyền thông (Secure Chat Server) hiệu năng cao, ứng dụng mô hình Client-Server với các mục tiêu cụ thể như sau:

- Tối ưu hóa hiệu năng xử lý đồng thời: Ứng dụng các công nghệ điều khiển sự kiện bất đồng bộ (I/O Multiplexing với epoll) và mô hình Thread Pool để giải quyết triệt để bài toán C10K, đảm bảo hệ thống duy trì hàng chục nghìn kết nối mạng với độ trễ tối thiểu và không xảy ra hiện tượng thất cổ chai I/O.
- Thiết kế giao thức truyền tải tối ưu: Xây dựng một giao thức gói tin nhị phân tùy chỉnh (Custom Binary Protocol) nhằm loại bỏ chi phí phân tích cú pháp (parsing overhead) và tiết kiệm băng thông mạng so với các giao thức dựa trên văn bản thông thường.
- Tích hợp hệ sinh thái an ninh mạng đa lớp: Triển khai mô hình mã hóa lai (Hybrid Crypto) sử dụng RSA-2048 để trao đổi khóa và AES-256-GCM để mã hóa tải trọng (payload). Đồng thời, xây dựng các module bảo mật chủ động trực tiếp trong nhân máy chủ bao gồm: Hệ thống phát hiện xâm nhập (IDS), Cơ chế giới hạn lưu lượng (Rate Limiter sử dụng thuật toán Token-Bucket) và Hệ thống nhật ký kiểm toán (Audit Logger).
- Đảm bảo tính nhất quán dữ liệu: Sử dụng hệ quản trị cơ sở dữ liệu SQLite kết hợp với cơ chế Write-Ahead Logging (WAL) để đảm bảo an toàn dữ liệu và tối ưu tốc độ truy vấn trong môi trường đa luồng.

2. Phạm vi nghiên cứu và triển khai

Trong khuôn khổ của đồ án, phạm vi nghiên cứu và triển khai được giới hạn ở các khía cạnh sau:

- Phạm vi kiến trúc hệ thống: Tập trung chuyên sâu vào việc xây dựng kiến trúc lõi của phần mềm Máy chủ (Server-side) bằng ngôn ngữ C++ hiện đại. Phần mềm Máy khách (Client-side) được phát triển dưới dạng giao diện dòng lệnh

(CLI), đóng vai trò như một công cụ tương tác thực tế để kiểm chứng hiệu quả của các tính năng nghiệp vụ.

- Phạm vi tính năng nghiệp vụ Hệ thống: triển khai đầy đủ các tính năng giao tiếp cốt lõi bao gồm: Nhắn tin cá nhân (Direct Message), Nhắn tin và quản lý phòng trò chuyện nhóm (Rooms), Truyền tải tập tin (File Transfer) và các Tập lệnh quản trị viên (Admin Commands).
- Phạm vi đánh giá và kiểm định: Đề tài tập trung đo lường năng lực xử lý (benchmark) dưới điều kiện tải cao và mô phỏng các kịch bản tấn công mạng cơ bản (như DoS, quét cổng, giả mạo gói tin) nhằm kiểm chứng năng lực phòng thủ của các module an ninh. Đề tài không mở rộng nghiên cứu sang việc phát triển giao diện đồ họa người dùng (GUI) hay các nền tảng ứng dụng di động.

1.2 Phân tích yêu cầu hệ thống

1.2.1 Yêu cầu chức năng

Dựa trên mục tiêu xây dựng một nền tảng trò chuyện bảo mật và hiệu năng cao, hệ thống cần đáp ứng các nhóm yêu cầu chức năng cốt lõi sau đây:

1. Quản lý Tài khoản và Xác thực (Authentication & Authorization):

- Cung cấp tính năng Đăng ký (Register) và Đăng nhập (Login) an toàn. Mật khẩu người dùng không lưu bản rõ mà phải qua các hàm băm mật mã (như SHA256/bcrypt) để đảm bảo an toàn cơ sở dữ liệu.
- Cấp phát thẻ định danh phiên (Session Token) sử dụng chữ ký điện tử HMAC, hỗ trợ cơ chế tự động phục hồi kết nối (Session Resumption) giúp người dùng giữ nguyên phiên đăng nhập khi mạng chập chờn.

2. Quản lý phiên kết nối và Trạng thái (Session Management):

- Quản lý vòng đời socket (Connect, Disconnect) và duy trì tín hiệu sống sót thông qua cơ chế nhịp tim (Ping/Pong).
- Hỗ trợ tra cứu danh sách người dùng đang trực tuyến (List Users) và xem thông tin hồ sơ của một tài khoản cụ thể (Whois).

3. Giao tiếp và Nhắn tin thời gian thực (Realtime Chatting):

- Nhắn tin cá nhân (Direct Message): Cho phép trao đổi thông điệp trực tiếp 1-1 với độ trễ tối thiểu.

- Nhắn tin nhóm (Room Chat): Hỗ trợ danh sách phòng trò chuyện (List Rooms), cho phép người dùng tạo phòng mới (Create Room), tham gia (Join), rời phòng (Leave) và gửi tin nhắn quảng bá (Broadcast) tới toàn bộ thành viên.
- Hỗ trợ truy vấn lịch sử trò chuyện đã được lưu trữ bền vững trong cơ sở dữ liệu.

4. Truyền tải tập tin (File Transfer):

- Cung cấp quy trình gửi/nhận tập tin hai chiều với luồng kiểm soát rõ ràng: gửi yêu cầu truyền (File Request) và chờ phía nhận xác nhận (Accept/Reject).
- Dữ liệu tập tin được chia nhỏ và truyền theo từng khối (Chunking) để tránh việc một tập tin dung lượng lớn chiếm dụng và gây tắc nghẽn luồng xử lý thông điệp chính của hệ thống.

5. Quản trị hệ thống (Admin Commands):

- Phân tách vai trò và cấp quyền Quản trị viên (Admin Privilege) để điều hành cộng đồng.
- Tích hợp bộ công cụ xử lý vi phạm: kích xuất người dùng (Kick), cấm gửi tin nhắn (Mute), cấm truy cập vĩnh viễn (Ban IP/Username), thăng cấp quyền (Promote) và gửi thông báo khẩn cấp tới toàn server (System Broadcast).

6. Cơ chế phòng vệ và An ninh chủ động (Security):

- Bắt tay mật mã (Crypto Handshake): Tự động trao đổi khóa (Key Exchange) ngay khi khởi tạo kết nối để thiết lập kênh truyền mã hóa bảo mật trước khi cho phép trao đổi dữ liệu nghiệp vụ.
- Ngăn chặn lạm dụng (Rate Limiting): Áp dụng thuật toán giới hạn tốc độ nhằm chống lại các nỗ lực tấn công từ chối dịch vụ (DoS) hoặc nhồi nhét tin nhắn rác (Spam).
- Hệ thống phát hiện xâm nhập (IDS): Tự động ghi nhận và phân loại các vi phạm (sai mật khẩu, quét cổng, gửi gói tin dị dạng) để trừ điểm rủi ro, từ đó ra quyết định cấm (Ban) tạm thời hoặc vĩnh viễn đối với các IP độc hại.

1.2.2 Yêu cầu phi chức năng

Bên cạnh các tính năng nghiệp vụ cốt lõi, hệ thống đặc biệt chú trọng vào các yêu cầu phi chức năng nhằm đảm bảo năng lực vận hành, độ tin cậy và an toàn thông tin toàn diện trong môi trường thực tế:

1. Hiệu năng và Khả năng mở rộng (Performance & Scalability):

- Khả năng xử lý đồng thời: Kiến trúc máy chủ phải được thiết kế dựa trên cơ chế I/O đa kênh (I/O Multiplexing) thông qua API epoll kết hợp với mô hình Thread Pool. Thiết kế này đảm bảo luồng điều phối chính không bao giờ bị nghẽn (non-blocking), giải quyết hiệu quả bài toán C10K với khả năng duy trì hàng chục nghìn kết nối mà vẫn giữ độ trễ ở mức tối thiểu.
- Tối ưu hóa băng thông truyền tải: Áp dụng giao thức mạng nhị phân tùy chỉnh (Custom Binary Protocol) thay thế cho văn bản thuần túy nhằm tối thiểu hóa kích thước gói tin, tiết kiệm băng thông và giảm thiểu hao phí CPU trong quá trình phân tích cú pháp (parsing).

2. Bảo mật và Toàn vẹn dữ liệu (Security & Integrity):

- Mã hóa kênh truyền: Toàn bộ lưu lượng mạng lưới phải được mã hóa tải trọng theo tiêu chuẩn công nghiệp (AES-256-GCM), với khóa phiên (Session Key) được thỏa thuận và phân phối an toàn thông qua cơ chế mã hóa khóa công khai (RSA-2048).
- Xác thực tính nguyên vẹn: Sử dụng mã kiểm lỗi (CRC32) và mã xác thực thông điệp (HMAC) trên từng gói tin để ngăn chặn mọi hành vi đánh tráo, sửa đổi trái phép dữ liệu trên đường truyền.
- An toàn lưu trữ dữ liệu: Mật khẩu người dùng bắt buộc phải được băm một chiều an toàn trước khi lưu. Hệ thống cơ sở dữ liệu nội bộ (SQLite) phải áp dụng cơ chế ghi chép trước nhật ký (Write-Ahead Logging) để duy trì tính nhất quán, không làm hỏng file dữ liệu ngay cả khi hệ thống gặp sự cố đột ngột.

3. Tính tin cậy và Khả năng chịu lỗi (Reliability & Fault Tolerance):

- Quản lý tài nguyên chặt chẽ: Tự động dọn dẹp và thu hồi toàn bộ tài nguyên (socket, phiên đăng nhập, vùng nhớ cấp phát) của các kết nối chết, ngắt kết nối đột ngột hoặc vi phạm thời gian chờ (Timeout). Quy trình này giúp triệt tiêu hoàn toàn rủi ro cạn kiệt bộ mô tả tệp (File Descriptor Exhaustion) và rò rỉ bộ nhớ (Memory Leak).
- Khả năng phục hồi luồng dữ liệu mạng: Xây dựng bộ đệm mạng (Network Buffer) độc lập cho từng kết nối với năng lực tự động xử lý các rủi ro đặc thù của luồng truyền TCP, bao gồm hiện tượng phân mảnh gói tin (TCP Fragmentation) và dính gói (TCP Sticky Packets), đảm bảo quá trình đọc/ghi dữ liệu luôn trọn vẹn và không gây sập đổ tiến trình.

CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

2.1 Kiến trúc mạng và giao thức

2.1.1 Mô hình Client-Server

Mô hình Khách - Chủ (Client-Server) là một kiến trúc mạng phân tán, trong đó khối lượng công việc và tài nguyên được phân chia rõ ràng giữa các thực thể cung cấp dịch vụ (được gọi là máy chủ - Server) và những thực thể yêu cầu dịch vụ (được gọi là máy khách - Client). Đây là mô hình nền tảng cho hầu hết các kiến trúc ứng dụng Internet hiện đại, đặc biệt là các hệ thống truyền thông và nhắn tin thời gian thực.

Trong cấu trúc này, máy chủ đóng vai trò là một nút mạng có năng lực tính toán cao, hoạt động liên tục (always-on) và luôn ở trạng thái lắng nghe các yêu cầu kết nối thông qua một cổng dịch vụ (Network Port) xác định. Nhiệm vụ cốt lõi của máy chủ là duy trì trạng thái của hệ thống, quản lý cơ sở dữ liệu tập trung, phân quyền truy cập, và điều phối/định tuyến các luồng dữ liệu. Ngược lại, máy khách là các thiết bị đầu cuối của người dùng, có nhiệm vụ chủ động khởi tạo yêu cầu kết nối đến máy chủ, gửi các chỉ thị nghiệp vụ và sau đó tiếp nhận dữ liệu trả về để hiển thị lên giao diện người dùng.

Việc ứng dụng mô hình Client-Server mang lại các ưu thế kỹ thuật vượt trội cho quá trình thiết kế hệ thống phần mềm:

- Tập trung hóa quản lý và Bảo mật (Centralized Security): Toàn bộ dữ liệu nhạy cảm (như mật khẩu bấm, lịch sử tin nhắn, khóa mã hóa) và logic nghiệp vụ lõi đều được lưu trữ và thực thi tại máy chủ. Thiết kế này giúp triệt tiêu rủi ro rò rỉ dữ liệu từ thiết bị đầu cuối và cho phép triển khai các lớp tường lửa, hệ thống phát hiện xâm nhập (IDS) một cách đồng bộ.
- Khả năng mở rộng (Scalability): Nhờ tính tách biệt (decoupled), hệ thống dễ dàng được mở rộng bằng cách nâng cấp tài nguyên phần cứng tại máy chủ hoặc cấu hình cân bằng tải (Load Balancing) mà không đòi hỏi bất kỳ sự sửa đổi nào từ phía hàng ngàn phần mềm máy khách.
- Tính nhất quán dữ liệu (Data Consistency): Việc mọi giao dịch dữ liệu đều đi qua một "nút thắt" trung tâm duy nhất là máy chủ giúp giải quyết triệt để vấn đề xung đột trạng thái dữ liệu (race conditions) so với các kiến trúc mạng ngang hàng (Peer-to-Peer).

Trong phạm vi của dự án này, máy chủ (Secure Chat Server) đóng vai trò trung tâm điều phối toàn bộ luồng giao tiếp mạng. Các máy khách (hoạt động dưới dạng giao diện dòng lệnh CLI) không thực hiện trao đổi dữ liệu trực tiếp với nhau. Mọi thông điệp giao tiếp đều bắt buộc phải được mã hóa và gửi đến máy chủ để thực hiện quá trình giải mã, kiểm duyệt nội dung, định tuyến (routing) và mã hóa lại trước khi phân phối đến đúng thiết bị đích.

2.1.2 Giao thức TCP/IP

Bộ giao thức TCP/IP (Transmission Control Protocol/Internet Protocol) là nền tảng giao tiếp cơ sở của mạng Internet. Trong mô hình phân tầng, Giao thức Điều khiển Truyền tải (TCP) hoạt động tại tầng Giao vận (Transport Layer), thiết lập kênh truyền thông tin cậy, hướng kết nối (Connection-oriented) và luân chuyển dữ liệu dưới dạng luồng byte (Byte-stream) giữa các tiến trình mạng.

Đối với hệ thống máy chủ nhắn tin bảo mật (Secure Chat Server), tính toàn vẹn và nhất quán của chuỗi thông điệp là yêu cầu tiên quyết. Do đó, giao thức TCP được chỉ định làm nền tảng truyền tải lỗi thay cho UDP (User Datagram Protocol) dựa trên các đặc tả kỹ thuật sau:

- Đảm bảo độ tin cậy (Reliability): TCP kiểm soát tính toàn vẹn của gói tin thông qua cơ chế tổng kiểm tra (Checksum) và tín hiệu xác nhận (Acknowledgment - ACK). Các phân đoạn dữ liệu (Segments) bị lỗi hoặc thất lạc trong quá trình định tuyến sẽ được cơ chế giao thức tự động phát lại (Retransmission).
- Duy trì thứ tự thông điệp (Ordered Delivery): Thuật toán đánh số thứ tự (Sequence Numbering) cho phép thực thể TCP phía nhận tổ chức và sắp xếp lại các phân đoạn dữ liệu đến sai trình tự (Out-of-order packets). Đây là yêu cầu kỹ thuật bắt buộc đối với các ứng dụng nhắn tin nhằm đảm bảo luồng hội thoại được tái tạo chính xác so với thời điểm phát.
- Kiểm soát luồng và Tắc nghẽn (Flow & Congestion Control): Cơ chế cửa sổ trượt (Sliding Window) tự động điều phối thông lượng phát dữ liệu dựa trên dung lượng bộ đệm của nút đích và trạng thái băng thông mạng. Thuật toán này giúp hạn chế tình trạng quá tải nút mạng và ngăn ngừa rủi ro nghẽn mạng toàn cục (Network Congestion).

Đặc trưng truyền tải dữ liệu theo định dạng luồng byte liên tục (Stream-oriented) của TCP tạo ra một vấn đề kỹ thuật đặc thù trong quá trình phát triển ứng dụng mạng: giao

thức không duy trì ranh giới thông điệp (Message Boundary) ở tầng ứng dụng. Đặc tính này trực tiếp dẫn đến hai hiện tượng:

- Hiện tượng dính gói (TCP Sticky Packets): Phát sinh khi phía gửi phát đi liên tiếp nhiều thông điệp có kích thước nhỏ. Thuật toán Nagle tại tầng TCP hoặc cơ chế quản lý bộ đệm (Buffer) của hệ điều hành sẽ tự động gộp các thông điệp này thành một phân đoạn mạng (Segment) duy nhất nhằm tối ưu hóa thông lượng truyền tải.
- Hiện tượng phân mảnh gói tin (TCP Fragmentation): Xảy ra khi thông điệp ứng dụng có kích thước vượt quá giới hạn đơn vị truyền tải tối đa (Maximum Transmission Unit - MTU) của hạ tầng mạng. Khối dữ liệu sẽ bị phân tách thành nhiều phân đoạn TCP rời rạc, khiến hệ thống tiếp nhận không thể trích xuất toàn bộ thông điệp chỉ thông qua một lời gọi hệ thống (System Call) duy nhất.

Nhằm khắc phục tình trạng này, kiến trúc hệ thống yêu cầu thiết lập một giao thức định khung (Framing Protocol) độc lập tại tầng ứng dụng, kết hợp với cơ chế quản lý bộ đệm mạng (Network Buffer). Kỹ thuật này đảm nhiệm việc tích lũy các luồng byte rời rạc từ hệ điều hành, phân giải thông tin chiều dài và tái tổ hợp (Reassembly) các phân đoạn thành một cấu trúc thông điệp nghiệp vụ hoàn chỉnh trước khi chuyển giao cho lớp logic xử lý.

2.2 Công nghệ mã hóa và bảo mật

2.2.1 Mã hóa đối xứng AES

Mật mã khóa đối xứng (Symmetric-key Cryptography) là một lớp các thuật toán mật mã học sử dụng chung một khóa duy nhất cho cả hai quá trình chuyển đổi văn bản rõ thành văn bản mã (Encryption) và quá trình ngược lại (Decryption). Tiêu chuẩn Mã hóa Nâng cao (Advanced Encryption Standard - AES) hiện là thuật toán mã hóa khối (Block Cipher) tiêu chuẩn được ứng dụng rộng rãi nhất, do Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) phê duyệt.

Thuật toán AES vận hành dựa trên mạng thay thế - hoán vị (Substitution-Permutation Network), xử lý các khối dữ liệu đầu vào có kích thước cố định 128-bit. Độ an toàn của thuật toán tỷ lệ thuận với chiều dài của khóa mật mã, được chuẩn hóa ở các mức 128-bit, 192-bit và 256-bit. Trong thiết kế kiến trúc của dự án, hệ thống áp dụng AES-256 (sử dụng khóa 256-bit), cung cấp không gian khóa đủ lớn để kháng cự lại các kỹ thuật tấn công vét cạn (Brute-force Attack) dưới điều kiện năng lực tính toán hiện tại.

Do đặc thù của mã hóa khối nguyên thủy chỉ xử lý các phân đoạn dữ liệu một cách

độc lập, thuật toán yêu cầu tích hợp với một chế độ hoạt động (Mode of Operation) nhằm mã hóa các khối dữ liệu có kích thước thay đổi. Trong dự án này, chế độ GCM (Galois/Counter Mode) được triển khai làm cơ chế vận hành lõi nhờ các đặc tả kỹ thuật sau:

- Chuyển đổi mã hóa luồng (Stream Encryption): Cơ chế GCM tích hợp một biến đếm tuần tự (Counter) để biến đổi thuật toán mã hóa khối thành mã hóa luồng, cho phép hệ thống tiến hành mã hóa thông điệp mà không cần áp dụng kỹ thuật chèn dữ liệu đệm (Padding). Yếu tố này giúp giảm thiểu hao phí kích thước (Overhead) đối với các gói tin mạng.
- Mã hóa xác thực (Authenticated Encryption): Bên cạnh chức năng mã hóa bảo mật, AES-GCM tự động sinh ra một thẻ xác thực (Authentication Tag) thông qua hàm băm nội tại trên trường Galois. Kỹ thuật này cung cấp cơ chế Xác thực Dữ liệu Bổ sung (Authenticated Data - AD), đảm bảo tính toàn vẹn của tải trọng thông điệp và ngăn chặn nguy cơ giả mạo văn bản mã (Ciphertext Tampering).
- Năng lực tính toán song song: Khác với các chế độ phản hồi chuỗi như CBC (Cipher Block Chaining), kiến trúc dựa trên bộ đếm của GCM cho phép các khối dữ liệu được mã hóa và giải mã hoàn toàn độc lập. Đặc tính này mang lại khả năng thực thi tính toán song song, giúp tối ưu hóa thời gian xử lý mật mã tại phía máy chủ đa luồng.

Trong sơ đồ luồng dữ liệu của hệ thống, AES-256-GCM được chỉ định làm giao thức mã hóa cho toàn bộ gói tin (Payload) của tiến trình giao tiếp. Khóa phiên đối xứng (Symmetric Session Key) sử dụng cho AES được khởi tạo ngẫu nhiên tại máy khách, sau đó được trao đổi an toàn với máy chủ thông qua giao thức mã hóa bất đối xứng trong pha thiết lập kết nối (Handshake).

2.2.2 Mã hóa bất đối xứng RSA

Mật mã khóa bất đối xứng (Asymmetric-key Cryptography), hay thuật toán khóa công khai (Public-key Cryptography), là một hệ thống mật mã dựa trên cặp khóa toán học có liên hệ mật thiết: một khóa công khai (Public Key) dùng cho tác vụ mã hóa và một khóa bí mật (Private Key) chuyên biệt cho tác vụ giải mã. RSA (Rivest-Shamir-Adleman) là một trong những giao thức nền tảng thuộc lớp thuật toán này, được chuẩn hóa và triển khai rộng rãi trong các hệ thống truyền thông an toàn.

An toàn cấu trúc của RSA phụ thuộc vào tính bất khả thi về mặt tính toán của bài toán phân tích thừa số nguyên tố (Integer Factorization) đối với các số nguyên lớn. Theo thiết kế, khóa công khai được phân phối công khai trên môi trường mạng mà không gây ảnh

hưởng đến tính bảo mật của hệ thống, bởi vì chi phí thời gian để nội suy khóa bí mật từ khóa công khai vượt quá khả năng xử lý của các kiến trúc máy tính truyền thống đương đại.

Hạn chế kỹ thuật của RSA so với thuật toán khóa đối xứng (như AES) nằm ở độ phức tạp tính toán lớn, dẫn đến thông lượng xử lý chậm hơn đáng kể. Vì vậy, trong thực tiễn thiết kế giao thức mạng, RSA không được ứng dụng để mã hóa trực tiếp các luồng dữ liệu tải trọng. Thay vào đó, thuật toán được chỉ định làm cơ sở cho cơ chế bao bọc và phân phối khóa (Key Wrapping & Distribution).

Trong kiến trúc hệ thống máy chủ (Secure Chat Server), thuật toán RSA với chuẩn khóa 2048-bit (RSA-2048) được triển khai nhằm thực thi quy trình thỏa thuận khóa (Key Exchange Handshake). Cơ chế này đảm nhiệm các chức năng kỹ thuật sau:

- Khởi tạo kênh phân phối an toàn: Thực thể máy khách (Client) sử dụng khóa công khai RSA của máy chủ để mã hóa khóa phiên đối xứng AES (Symmetric Session Key) nội bộ. Khóa công khai này được quy định sẵn hoặc trích xuất từ các chứng chỉ phân phối tĩnh.
- Ngăn chặn tấn công trung gian (Man-in-the-Middle): Khóa phiên đối xứng ở định dạng bản mã được luân chuyển qua hạ tầng mạng và chỉ cho phép giải mã bởi máy chủ sở hữu khóa bí mật RSA tương ứng. Quá trình này vô hiệu hóa hoàn toàn nguy cơ đánh cắp khóa phiên thông qua kỹ thuật bắt gói tin (Packet Sniffing).
- Kiến trúc mã hóa lai (Hybrid Encryption): Sau khi hoàn tất quy trình trao đổi khóa RSA, giao thức kết nối tự động chuyển đổi sang sử dụng AES cho toàn bộ tải trọng thông điệp. Sự tích hợp này giải quyết trọn vẹn bài toán tối ưu hóa tài nguyên tính toán trong khi vẫn duy trì chuẩn mực bảo mật cao nhất đối với khâu xác thực định danh và thiết lập phiên giao dịch.

2.2.3 Hàm băm SHA-256 và xác thực HMAC

Hàm băm mật mã (Cryptographic Hash Function) là một thuật toán toán học làm nhiệm vụ ánh xạ một khối dữ liệu có kích thước tùy biến thành một chuỗi bit có kích thước cố định, được gọi là giá trị băm (Hash Value) hoặc bản tóm tắt (Message Digest). Thuật toán Băm An toàn 256-bit (Secure Hash Algorithm 256-bit - SHA-256) thuộc tiêu chuẩn SHA-2 hiện là một trong những chuẩn băm được ứng dụng phổ biến và an toàn nhất trong ngành khoa học mật mã.

Thuật toán SHA-256 đáp ứng đầy đủ các tính chất toán học trọng yếu của một hàm băm mật mã: tính một chiều (Pre-image Resistance - tính bất khả thi trong việc suy ngược

dữ liệu gốc từ giá trị băm), tính chống đụng độ (Collision Resistance - xác suất tìm thấy hai tập dữ liệu đầu vào khác nhau nhưng cho ra cùng một giá trị băm là không đáng kể về mặt thống kê), và hiệu ứng sạt lở (Avalanche Effect - sự thay đổi ở cấp độ bit đối với dữ liệu đầu vào sẽ làm hoán vị toàn cục đối với cấu trúc của giá trị băm đầu ra). Trong dự án này, chức năng cốt lõi của SHA-256 là tiến hành băm một chiều mật khẩu người dùng trước khi định dạng vào cơ sở dữ liệu, đảm bảo thông tin người dùng không thể bị nội suy ngay cả khi phân vùng lưu trữ vật lý bị xâm nhập.

Mặc dù đảm bảo được tính toàn vẹn (Integrity) của luồng thông tin, hàm băm nguyên thủy không cung cấp khả năng xác thực nguồn gốc định danh (Authenticity), do bất kỳ thực thể nào cũng sở hữu khả năng tự do tính toán lại một giá trị băm mới đối với một văn bản đã bị sửa đổi. Nhằm bao quát vấn đề này, Mã xác thực thông điệp dựa trên hàm băm (Hash-based Message Authentication Code - HMAC) được tích hợp bổ trợ. Thuật toán HMAC thực thi phép băm (điển hình là HMAC-SHA256) đối với thông điệp kết hợp cùng một khóa đối xứng (Secret Key), vốn chỉ được chia sẻ phân quyền giữa các thiết bị hợp lệ.

Trong thiết kế kiến trúc của máy chủ truyền thông (Secure Chat Server), kỹ thuật HMAC-SHA256 được vận dụng vào các tiến trình bảo vệ vòng đời giao tiếp như sau:

- Kháng giả mạo và bảo vệ toàn vẹn thông điệp (Message Authentication): Mỗi gói tin mạng (Network Packet) truyền đi đều mang theo một khối mã HMAC, sinh ra từ gói dữ liệu đối chiếu với khóa phiên (Session Key). Lớp xử lý mạng tại hệ thống tiếp nhận sẽ tính toán song song mã HMAC để nghiệm chứng. Cơ chế này cho phép phát hiện và loại bỏ tức thì các luồng dữ liệu bị can thiệp (Tampering) hoặc bị chèn trái phép từ các kết nối không xác thực.
- Xác thực thông báo phiên (Session Token Validation): Máy chủ triển khai cơ chế cấp phát mã thông báo (Token) định danh có gắn kèm chữ ký HMAC-SHA256 để định tuyến người dùng. Phương thức này không những ngăn chặn hành vi giả mạo mã thông báo (Token Forgery) mà còn củng cố trạng thái vận hành phi tập trung (Stateless), giúp giải phóng tài nguyên bộ nhớ cho hệ thống thay vì phải bảo lưu phiên làm việc cục bộ.

2.3 Công nghệ xử lý đồng thời và hiệu năng cao

2.3.1 I/O Multiplexing và mô hình epoll

I/O Multiplexing (Ghép kênh vào/ra) là một kỹ thuật lập trình hệ thống cho phép một tiến trình có khả năng giám sát đồng thời nhiều bộ mô tả tệp (File Descriptor - FD) nhằm

xác định trạng thái sẵn sàng của các thao tác vào/ra (đọc, ghi dữ liệu). Kỹ thuật này là phương pháp luận chính để giải quyết bài toán C10K (Concurrent 10,000 connections), khắc phục giới hạn về tài nguyên bộ nhớ và hao phí chuyển ngữ cảnh (Context Switching) của mô hình định tuyến đa luồng truyền thống (thread-per-connection) khi phải duy trì một lượng lớn các kết nối mạng nhàn rỗi.

Trong môi trường hệ điều hành phân phối nhân Linux, cơ chế `epoll` được xem là chuẩn mực tối ưu để triển khai I/O Multiplexing, thay thế cho các cơ chế `select()` và `poll()` thế hệ cũ. Kiến trúc nội tại của `epoll` mang lại khả năng mở rộng (Scalability) cao dựa trên các đặc tả kỹ thuật sau:

- Lưu trữ trạng thái cấu trúc tại Không gian hạt nhân (Kernel-space): Đối với các cơ chế cũ, toàn bộ cấu trúc mảng File Descriptor phải được sao chép từ không gian người dùng (User-space) vào Kernel-space trong mỗi lời gọi hệ thống. Ngược lại, `epoll` thiết lập và duy trì một cấu trúc cây đỏ - đen (Red-Black Tree) trực tiếp tại Kernel-space, qua đó triệt tiêu hoàn toàn chi phí sao chép dữ liệu tuyến tính khi số lượng kết nối mạng gia tăng đột biến.
- Thông báo trạng thái hướng sự kiện (Event-driven Notification): Thay vì quét toàn bộ danh sách File Descriptor theo dạng vòng lặp tuyến tính (Polling), `epoll` tích hợp với trình điều khiển ngắt của thiết bị mạng. Khi một sự kiện mạng phát sinh, hệ thống hàm gọi lại (Callback) sẽ tự động chèn FD tương ứng vào một danh sách sẵn sàng (Ready List). Độ phức tạp thuật toán để trích xuất danh sách này chỉ dừng ở mức $O(1)$ thay vì $O(N)$.
- Chế độ kích hoạt mức biên (Edge-Triggered - ET): `epoll` hỗ trợ hai chế độ kích hoạt là Level-Triggered (LT) và Edge-Triggered (ET). Ở chế độ ET, hệ điều hành chỉ phát tín hiệu ngắt một lần duy nhất tại thời điểm trạng thái của FD chuyển dịch từ không sẵn sàng sang sẵn sàng. Điều này giúp giảm thiểu đáng kể số lượng lời gọi hệ thống (System Call) so với cơ chế thông báo lặp lại của LT.

Trong kiến trúc thiết kế của Secure Chat Server, mô hình `epoll` được định cấu hình vận hành ở chế độ Edge-Triggered kết hợp chặt chẽ với các socket mạng dạng phi đồng bộ (Non-blocking Socket). Luồng thực thi lõi (Main Thread) đóng vai trò là một Vòng lặp sự kiện (Event Loop), chuyên trách đảm nhận việc thu thập các sự kiện từ `epoll` và điều phối tải trọng công việc sang các luồng nghiệp vụ tương ứng mà không bị gián đoạn bởi các thao tác I/O.

2.3.2 Mô hình Thread Pool

Trong phương pháp lập trình đa luồng đơn sơ, chiến lược định tuyến dựa trên nguyên tắc khởi tạo một luồng thực thi (Thread) mới tương ứng với mỗi yêu cầu đầu vào (thread-per-request) bộc lộ giới hạn nghiêm trọng về thông lượng khi hệ thống tiếp nhận tải trọng lớn. Quá trình tạo lập và hủy phân bổ luồng liên tục yêu cầu chi phí tài nguyên đáng kể về chu kỳ CPU (CPU Cycles) và dung lượng vùng nhớ cục bộ (Thread Stack). Thêm vào đó, việc duy trì đồng thời hàng nghìn luồng độc lập dẫn đến suy giảm hiệu năng tổng thể của hệ điều hành, xuất phát từ hao phí chuyển đổi ngữ cảnh (Context Switching) và sự cạnh tranh bộ định thời (Scheduling Contention).

Mô hình Thread Pool là một mẫu thiết kế phần mềm (Design Pattern) được sử dụng nhằm hệ thống hóa vòng đời quản trị tài nguyên tính toán song song. Khác với cơ chế phân rã động, kiến trúc này khởi tạo sẵn một lượng luồng làm việc (Worker Threads) xác định và đặt chúng vào trạng thái chờ tĩnh (Idle). Các luồng thực thi này được tái sử dụng xoay vòng để giải quyết chuỗi tác vụ đẩy vào hệ thống thông qua một bộ đệm dữ liệu trung gian, phổ biến nhất là Hàng đợi tác vụ (Task Queue).

Việc ứng dụng cấu trúc Thread Pool mang lại các cơ chế tối ưu hóa hệ thống cốt lõi sau:

- Tái sử dụng vùng nhớ cấp phát (Resource Reuse): Triệt tiêu chi phí tương tác Kernel (Kernel interaction) phát sinh từ tác vụ sinh và hủy luồng liên tục. Luồng làm việc tự động thu nhận tác vụ tiếp theo từ hàng đợi ngay sau khi hoàn tất phiên xử lý hiện tại, duy trì trạng thái hoạt động dài hạn.
- Giới hạn khả năng tương tranh (Concurrency Bounding): Thông qua việc cấu hình giới hạn tĩnh đối với số lượng luồng làm việc (thông thường được tham chiếu theo cấu trúc lõi vật lý của vi xử lý), kiến trúc thiết lập cơ chế giới hạn tài nguyên hệ thống (Resource Limiting). Yếu tố này củng cố khả năng phòng vệ của hệ thống trước tình trạng cạn kiệt bộ nhớ (OOM - Out of Memory) do xử lý quá tải.
- Cấu trúc điều phối đồng bộ chặt chẽ: Mô hình tích hợp các cơ chế đồng bộ hóa luồng tiêu chuẩn như Khóa loại trừ lẫn nhau (Mutex Lock) và Biến điều kiện (Condition Variable). Sự kết hợp này bảo vệ tính nguyên tử (Atomicity) khi các luồng cùng thực thi thao tác cấu trúc trên Hàng đợi tác vụ, đồng thời cho phép đánh thức luồng tĩnh một cách chính xác.

Trong sơ đồ vận hành của Secure Chat Server, Thread Pool được triển khai tuân theo mẫu thiết kế Producer-Consumer. Luồng thực thi mạng (Event Loop kết hợp API `epoll`) đảm nhiệm vai trò Producer, liên tục chuyển đổi các luồng byte thu nhận thành các khối

tác vụ và nạp vào Hàng đợi. Tập hợp Worker Threads đảm nhiệm vai trò Consumer, tiến hành trích xuất tác vụ để thực hiện các tiến trình giải mã, tính toán xác thực, truy vấn dữ liệu và định tuyến lại mạng lưới. Sự phân tách trách nhiệm (Decoupling) này bảo đảm luồng I/O mạng luôn ở trạng thái đáp ứng (Responsive), hoàn toàn cách ly khỏi độ trễ do các thao tác sử dụng nhiều CPU (CPU-bound) gây ra.

2.4 Lý thuyết an ninh mạng

2.4.1 Hệ thống phát hiện xâm nhập (IDS)

Hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) là một thành phần kiến trúc an ninh mạng chuyên trách giám sát các luồng lưu lượng và hoạt động của hệ thống nhằm phân tích, nhận diện các dấu hiệu bất thường hoặc các nỗ lực can thiệp trái phép. Trong bối cảnh các máy chủ cung cấp dịch vụ luôn phải đối mặt với rủi ro bị quét lỗ hổng và tấn công mạng, IDS vận hành như một lớp phòng ngự chủ động (Proactive Defense), cung cấp cơ chế phân tích và phản ứng tự động để bảo vệ tính sẵn sàng của dịch vụ.

Về phương pháp luận, các hệ thống IDS định tuyến lưu lượng thường được xây dựng dựa trên hai mô hình cốt lõi:

- Phân tích dựa trên dấu hiệu (Signature-based Detection): Hệ thống tiến hành đối chiếu cấu trúc gói tin (Payload) và tham số của gói tin đầu vào với một cơ sở dữ liệu chứa các đặc tả tấn công đã biết (Threat Signatures). Cơ chế này đạt độ chính xác cao đối với các kỹ thuật tấn công phổ quát, nhưng không có năng lực nhận diện các biến thể hoặc lỗ hổng chưa được công bố (Zero-day Exploits).
- Phân tích dựa trên hành vi bất thường (Anomaly-based Detection): Hệ thống thiết lập một đường cơ sở (Baseline) đại diện cho trạng thái hoạt động bình thường của hệ thống mạng. Bất kỳ sự sai lệch nào vượt quá ngưỡng thống kê (diễn hình như chuỗi yêu cầu đăng nhập thất bại liên tục, hoặc lưu lượng truy cập gia tăng đột biến từ một nguồn duy nhất) đều được phân loại là một sự cố an ninh tiềm năng.

Trong kiến trúc bảo mật của dự án Secure Chat Server, module IDS được thiết kế theo hướng tiếp cận Host-based IDS (HIDS), tích hợp trực tiếp vào tầng ứng dụng. Cơ chế hoạt động của module tập trung vào việc giám sát hành vi tại cấp độ phiên kết nối:

- Cơ chế theo dõi và lưu vết sự kiện: Module IDS tiến hành lưu vết (Tracking) các sự kiện vi phạm an ninh của từng thực thể mạng (định danh qua địa chỉ IP). Danh mục các hành vi vi phạm được định nghĩa bao gồm: gửi gói tin sai định dạng cấu trúc

giao thức (Malformed Packets), không vượt qua nghiệm chứng chữ ký số (Invalid HMAC), hoặc thực thi tác vụ xác thực thất bại lặp lại.

- Cơ chế cô lập tự động (Auto-banning): Mỗi địa chỉ IP được hệ thống gán một chỉ số rủi ro (Risk Score). Khi tần suất vi phạm của một địa chỉ IP tính tiền vượt quá ngưỡng dung sai được lập trình sẵn (Tolerance Threshold), module IDS sẽ tự động kích hoạt tiến trình cấm truy cập (IP Banning) đối với nguồn này ở cấp độ mạng. Cơ chế này trực tiếp vô hiệu hóa các chiến dịch tấn công vét cạn mật khẩu (Brute-force Attack) và giảm thiểu tác động của các luồng tấn công từ chối dịch vụ (DoS) cấp ứng dụng.

2.4.2 Thuật toán Rate Limiting (Token-Bucket)

Kiểm soát lưu lượng (Rate Limiting) là một cơ chế quản trị tài nguyên mạng được thiết kế nhằm khống chế tần suất truyền tải yêu cầu từ phía máy khách (Client) tới máy chủ (Server) trong một khoảng thời gian xác định. Mục tiêu cốt lõi của cơ chế này là bảo vệ băng thông mạng, ngăn ngừa tình trạng suy thoái hiệu năng do các cuộc tấn công từ chối dịch vụ (Denial-of-Service - DoS), và bảo đảm nguyên tắc phân phối tài nguyên công bằng (Fairness) đối với toàn bộ các phiên kết nối tương tranh.

Trong số các thuật toán giới hạn định tuyến, thuật toán Token-Bucket là một tiêu chuẩn kỹ thuật được ứng dụng rộng rãi nhờ khả năng duy trì thông lượng trung bình ổn định, đồng thời vẫn cho phép hệ thống hấp thụ các đợt lưu lượng gia tăng đột biến (Burst Traffic). Nguyên lý hoạt động toán học của thuật toán được mô hình hóa qua các tiên đề sau:

- Cấu trúc lưu trữ: Hệ thống duy trì một không gian lưu trữ Bucket với sức chứa giới hạn tối đa là N Token.
- Khả năng tái tạo: Các token được khởi tạo và nạp tuần tự vào Bucket theo một vận tốc tuyến tính không đổi R (số token trên mỗi đơn vị thời gian). Tại thời điểm Bucket đạt sức chứa tối đa N , mọi token sinh ra thêm đều bị hệ thống loại bỏ (Discarded).
- Cấp phép yêu cầu: Mỗi yêu cầu truy xuất tài nguyên hệ thống (như gửi tin nhắn, tải tệp) tiêu tốn một định mức token nhất định. Nếu số lượng token tồn dư trong Bucket lớn hơn hoặc bằng định mức yêu cầu, hệ thống chấp thuận xử lý (Accepted) và tiến hành khấu trừ số lượng token tương ứng. Ngược lại, nếu số dư token không đáp ứng đủ, yêu cầu sẽ bị hệ thống từ chối lập tức (Rejected) hoặc đưa vào hàng đợi chờ (Queued).

Đối với cấu trúc của dự án Secure Chat Server, module Rate Limiter vận hành dựa trên thuật toán Token-Bucket được thiết kế để thực thi giới hạn lưu lượng trên phạm vi từng phiên kết nối độc lập (Per-connection Rate Limiting). Việc triển khai cơ chế này định hình các chức năng điều phối sau:

- Giám sát vi mô: Hệ thống áp đặt giới hạn cấu trúc về số lượng thông điệp tải trọng và yêu cầu truy xuất cơ sở dữ liệu mà một máy khách được phép thực hiện. Chức năng này phong tỏa hoàn toàn các hành vi phát tán thư rác (Spamming) ở cấp độ ứng dụng, bảo vệ bộ đệm mạng (Network Buffer) khỏi nguy cơ tràn dữ liệu (Buffer Overflow).
- Tích hợp Module An ninh: Thuật toán Rate Limiting được thiết kế để tương tác trực tiếp với Hệ thống phát hiện xâm nhập (IDS). Các sự kiện yêu cầu bị từ chối do vi phạm số lượng Token sẽ được ghi nhận và chuyển tiếp làm tham số đầu vào cho module IDS. Tần suất vi phạm bằng thông cao sẽ dẫn đến sự gia tăng của chỉ số rủi ro (Risk Score), từ đó kích hoạt cơ chế cô lập IP tự động (Auto-banning) nhằm vô hiệu hóa hoàn toàn nguồn phát sinh lưu lượng độc hại.

2.5 Hệ thống lưu trữ và cơ sở dữ liệu

2.5.1 Cơ sở dữ liệu SQLite

SQLite là một thư viện phần mềm mã nguồn mở cung cấp hệ quản trị cơ sở dữ liệu quan hệ (Relational Database Management System - RDBMS) với đặc trưng kiến trúc phi máy chủ (Serverless) và không yêu cầu cấu hình cài đặt (Zero-configuration). Khác biệt hoàn toàn với các hệ quản trị cơ sở dữ liệu tuân theo mô hình khách - chủ (Client-Server) truyền thống như PostgreSQL hay MySQL, SQLite nhúng trực tiếp công cụ xử lý cơ sở dữ liệu vào ứng dụng phần mềm dưới định dạng một thư viện liên kết. Toàn bộ cấu trúc lưu trữ bao gồm bảng (Tables), chỉ mục (Indices) và dữ liệu định tuyến đều được tổ chức và đóng gói vào một tệp tin vật lý duy nhất trên hệ thống lưu trữ đĩa (Disk Storage).

Việc ứng dụng SQLite làm hạt nhân quản trị dữ liệu cho kiến trúc Secure Chat Server được củng cố bởi các tiêu chí kỹ thuật cụ thể sau:

- Tối ưu hóa độ trễ giao tiếp (IPC Latency Elimination): Nhờ kiến trúc phi máy chủ, các lời gọi truy vấn cơ sở dữ liệu được thực thi trực tiếp dưới dạng các lệnh gọi hàm cục bộ (Local Function Calls) trong cùng một không gian bộ nhớ của tiến trình. Cấu trúc này triệt tiêu hoàn toàn chi phí truyền tải qua mạng và độ trễ giao tiếp liên tiến trình (Inter-process Communication), tối ưu hóa thời gian đáp ứng cho các thao tác đọc/ghi.

- Tuân thủ nghiêm ngặt tiêu chuẩn ACID: Bất chấp dung lượng biên dịch nhỏ, SQLite triển khai đầy đủ các thuộc tính của một hệ thống giao dịch (Transaction): Tính nguyên tử (Atomicity), Tính nhất quán (Consistency), Tính cô lập (Isolation) và Tính bền vững (Durability). Các thuộc tính này cam kết tính toàn vẹn của dữ liệu hồ sơ người dùng và lịch sử tin nhắn ngay cả khi phát sinh sự cố mất điện phần cứng hoặc lỗi sập ứng dụng (Crash).
- Khả năng tương thích chéo (Cross-platform Portability): Định dạng tệp dữ liệu của cơ sở dữ liệu SQLite được chuẩn hóa ở cấp độ tổ chức byte, cho phép quản trị viên sao chép, sao lưu hoặc di chuyển dữ liệu xuyên suốt giữa các nền tảng hệ điều hành (như Linux, Windows, macOS) mà không phụ thuộc vào tiến trình chuyển đổi định dạng phức tạp.

Trong sơ đồ kiến trúc tổng thể, module SQLite đóng vai trò là tầng lưu trữ bền vững (Persistence Layer), chịu trách nhiệm duy trì các thực thể dữ liệu nghiệp vụ cốt lõi, bao gồm: hồ sơ định danh (thông tin đăng nhập, chứng thư xác thực) và nhật ký hội thoại. Việc tương tác với cơ sở dữ liệu được phân phối trực tiếp cho tập hợp luồng làm việc (Worker Threads) thực thi trong chu trình xử lý tải trọng mạng.

2.5.2 Cơ chế Write-Ahead Logging (WAL)

Write-Ahead Logging (WAL) là một phương pháp quản lý giao dịch (Transaction Management) được tích hợp trong hầu hết các hệ quản trị cơ sở dữ liệu quan hệ nhằm bảo toàn tính nguyên tử (Atomicity) và tính bền vững (Durability). Đối với cơ chế Rollback Journal truyền thống của SQLite, mọi thao tác sửa đổi dữ liệu đều yêu cầu hệ thống sao chép bản ghi gốc (Original Data) sang một tệp nhật ký khôi phục trước khi thực thi ghi đè trực tiếp lên tệp cơ sở dữ liệu chính. Cấu trúc này áp đặt một khóa độc quyền (Exclusive Lock) lên toàn bộ cấu trúc dữ liệu trong suốt vòng đời của giao dịch ghi, dẫn đến hệ quả làm gián đoạn toàn bộ các giao dịch truy vấn đọc đang diễn ra (Writers block Readers, Readers block Writers).

Nhằm khắc phục tình trạng tương tranh (Concurrency) kém hiệu quả này, cơ chế WAL tái cấu trúc phương thức lưu trữ: thay vì tiến hành ghi đè dữ liệu trực tiếp, mọi giao dịch cập nhật (Insert, Update, Delete) đều được tuần tự hóa và chèn (Append) vào một tệp nhật ký tuyến tính (WAL file). Đối với các giao dịch đọc, thuật toán truy xuất sẽ ưu tiên đối chiếu bản ghi mới nhất trong tệp WAL; trong trường hợp không tìm thấy, hệ thống mới tiến hành đọc phân đoạn tương ứng từ tệp cơ sở dữ liệu gốc. Một cơ chế đồng bộ hóa định kỳ (Checkpointing) sẽ đảm nhiệm việc hợp nhất (Merge) trạng thái thay đổi từ tệp WAL vào cơ sở dữ liệu chính.

Việc kích hoạt chế độ WAL trong SQLite thiết lập các năng lực vận hành quan trọng sau đối với các ứng dụng máy chủ đa luồng:

- Tối ưu hóa năng lực tương tranh (High Concurrency): Kiến trúc WAL cho phép hệ thống duy trì song song nhiều tiến trình đọc dữ liệu đồng thời với một tiến trình ghi dữ liệu. Khái niệm "Thao tác đọc không chặn thao tác ghi, và thao tác ghi không chặn thao tác đọc" tương thích hoàn hảo với mô hình phân luồng Thread Pool, đặc biệt trong các kịch bản mà tập hợp luồng làm việc phải liên tục nghiệm chứng định danh người dùng song song với việc lưu trữ thông điệp.
- Giảm thiểu hao phí phân mảnh đĩa (Disk I/O Overhead): Tác vụ ghi tuần tự nối tiếp (Sequential Append) lên tệp WAL yêu cầu số lượng thao tác đồng bộ đĩa `fsync()` ít hơn đáng kể so với thao tác phân mảnh và ghi đè ngẫu nhiên (Random Write) của Rollback Journal. Yếu tố này giúp cải thiện chu kỳ thực thi của các khối lệnh giao dịch mạng.

Trong phân tích kiến trúc của hệ thống Secure Chat Server, việc chuyển dịch phương thức lưu trữ sang định dạng WAL là một điều kiện kỹ thuật mang tính tiên quyết. Với đặc thù của giao thức nhắn tin trực tuyến yêu cầu tần suất tác vụ hỗn hợp (Mix of Reads and Writes) cường độ cao – điển hình như thao tác trích xuất chia khóa mã hóa (Read) đan xen liên tục với việc lưu vết lịch sử trò chuyện (Write) – cấu trúc WAL cung cấp giải pháp triệt để nhằm phòng tránh hiện tượng thắt nút cổ chai (Bottleneck) tại tầng dữ liệu cục bộ.

2.6 Công cụ và Thư viện phát triển

Quá trình xây dựng và phát triển dự án Secure Chat Server được triển khai dựa trên một hệ sinh thái các công cụ phần mềm và thư viện tiêu chuẩn, nhằm đảm bảo khả năng tối ưu hóa hiệu năng và tương thích chuyên sâu với kiến trúc hệ điều hành cục bộ:

- Ngôn ngữ lập trình C++: Dự án ứng dụng ngôn ngữ C++ (dựa trên tiêu chuẩn C++17) làm công cụ lập trình lõi. Năng lực can thiệp vi mô vào không gian bộ nhớ kết hợp cùng các giao diện trừu tượng hóa cấp thấp của C++ đóng vai trò then chốt trong việc lập trình socket mạng và quản trị chu kỳ sống của luồng thực thi (Thread Lifecycle).
- Hệ điều hành phân phối Linux (Linux Kernel): Máy chủ được thiết kế chuyên biệt để vận hành trong môi trường hệ điều hành Linux. Đặc điểm này xuất phát từ yêu cầu tích hợp trực tiếp Giao diện lập trình ứng dụng (API) `epoll` – một nền tảng I/O Multiplexing mang tính độc quyền của nhân Linux, phục vụ mục đích giải quyết kiến trúc tương tranh cấp độ cao.

- Thư viện mật mã OpenSSL: Được chỉ định làm nền tảng cung cấp các bộ hàm sinh mật mã (Cryptographic Primitives). Toàn bộ các quy trình nghiệp vụ bảo mật cốt lõi, bao gồm khởi tạo cơ chế trao đổi khóa RSA-2048, mã hóa tải trọng phân đoạn AES-256-GCM, và thuật toán băm xác thực HMAC-SHA256 đều được liên kết trực tiếp với thư viện OpenSSL.
- Thư viện cơ sở dữ liệu SQLite3: Thư viện ngôn ngữ C tĩnh (Static C Library) của SQLite3 được nhúng đồng thời vào mã nguồn dự án nhằm cung cấp năng lực xử lý dữ liệu phi máy chủ (Serverless). Module này thực thi nhiệm vụ phân tích ngữ pháp SQL, điều phối tập vật lý lưu trữ, và bảo toàn thuộc tính giao dịch ACID dưới sự hỗ trợ của chế độ Write-Ahead Logging.
- Hệ thống biên dịch GCC và Make: Quá trình dịch thuật mã nguồn tĩnh thành tệp thực thi nhị phân (Binary Executable) được triển khai thông qua Bộ trình dịch GNU (GNU Compiler Collection - GCC). Cấu trúc liên kết mã nguồn và quản trị sự phụ thuộc của các thư viện (Dependency Management) được cấu hình tự động thông qua các tập lệnh Makefile.

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

3.1 Kiến trúc tổng thể hệ thống

3.1.1 Kiến trúc Server

3.1.2 Kiến trúc Client

3.2 Thiết kế giao thức giao tiếp

3.2.1 Cấu trúc gói tin

3.2.2 Luồng xử lý thông điệp

3.3 Thiết kế cơ chế bảo mật

3.3.1 Cơ chế trao đổi khóa (Key Exchange)

3.3.2 Xác thực người dùng và Phục hồi phiên (Auth & Session Resumption)

3.4 Thiết kế hệ sinh thái an ninh mạng chủ động

3.4.1 Hệ thống phát hiện xâm nhập (IDS)

3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)

3.4.3 Nhật ký kiểm toán (Audit Logger)

3.5 Thiết kế cơ sở dữ liệu

3.5.1 Sơ đồ thực thể liên kết (ERD)

3.5.2 Quản lý người dùng và trạng thái

3.6 Thiết kế logic tính năng nghiệp vụ

3.6.1 Nhắn tin cá nhân và Bộ lọc nội dung (Direct Message & Message Filter)

3.6.2 Quản lý phòng Chat nhóm (Rooms)

3.6.3 Cơ chế truyền tải tập tin (File Transfer)

CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1 Kết luận

4.2 Hướng phát triển